

Esercitazione

Password Cracking

Corso	Cybersecurity & Ethical Hacking
Anno Accademico	2025/2026
Data	14 maggio 2026
Ambiente	Kali Linux 2026.1 + Metasploitable 2.0
Strumenti	sqlmap, John the Ripper, Hashcat, Hydra
Obiettivo	Estrazione e cracking di password hashate dal DB DVWA

Questa esercitazione e' stata svolta nell'ambito del Corso di Cybersecurity & Ethical Hacking con finalita' esclusivamente didattiche. Tutti i test sono stati condotti in un ambiente virtuale isolato e controllato, su macchine appositamente predisposte per la formazione. Nessuna delle tecniche descritte e' stata applicata su sistemi reali o senza autorizzazione.

1. Introduzione

In questa esercitazione ho affrontato il tema del password cracking, una delle attività più classiche nell'ambito del penetration testing. Il punto di partenza è stato il database della DVWA (Damn Vulnerable Web Application), ospitata sulla macchina Metasploitable 2.0 (192.168.1.170), dalla quale ho estratto gli hash delle password degli utenti tramite SQL injection automatizzata con sqlmap. Una volta ottenuto il file con gli hash in formato MD5, ho testato tre strumenti diversi per eseguire il cracking in modalità offline e online: John the Ripper, Hashcat e Hydra. L'obiettivo principale era comprendere le differenze di approccio tra questi tool e osservare i risultati che ciascuno di essi è in grado di produrre.

2. Obiettivi

#	Obiettivo
1	Estrarre gli hash delle password degli utenti DVWA tramite SQL injection con sqlmap
2	Crackare gli hash MD5 in modalità offline con John the Ripper e una wordlist
3	Eseguire il cracking degli stessi hash con Hashcat in modalità dizionario
4	Verificare le credenziali trovate direttamente sul form di login DVWA con Hydra
5	Confrontare i risultati ottenuti dai tre strumenti e identificare eventuali discrepanze

3. Ambiente e Strumenti

Componente	Dettagli
Kali Linux 2026.1 (attaccante)	IP: 192.168.1.164 VirtualBox, rete Bridged
Metasploitable 2.0 (target)	IP: 192.168.1.170 DVWA attiva, MySQL >= 4.1
sqlmap	Tool di SQL injection automatica per l'estrazione del database
John the Ripper	Strumento di cracking offline con supporto a dizionari e formati hash multipli
Hashcat	Cracker ad alte prestazioni, supporta GPU; usato in modalità dizionario (MD5)
Hydra v9.6	Tool di brute-force online su protocolli di rete, inclusi form HTTP/POST
rockyou.txt	Wordlist di riferimento con oltre 14 milioni di password reali

4. Procedura

STEP 1 **Analisi preliminare del target**

Prima di avviare qualsiasi operazione, ho verificato che entrambe le macchine virtuali fossero attive e raggiungibili nella rete locale. Ho controllato che la DVWA fosse accessibile all'indirizzo `http://192.168.1.170/dvwa` e che il database MySQL fosse in funzione. Ho anche verificato la presenza di `sqlmap` sulla macchina Kali con il comando `sqlmap --version` e controllato che `rockyou.txt` fosse disponibile nel percorso standard `/usr/share/wordlists/rockyou.txt`.

STEP 2 **Estrazione degli hash con sqlmap**

Ho lanciato `sqlmap` puntando alla pagina vulnerabile della DVWA e specificando il database e la tabella di interesse. `sqlmap` ha rilevato automaticamente il DBMS come MySQL (versione ≥ 4.1), il sistema operativo come Linux Ubuntu 8.04 (Hardy Heron) e la tecnologia applicativa come PHP 5.2.4 su Apache 2.2.8. Il tool ha identificato la vulnerabilit  di tipo UNION query e ha estratto i record dalla tabella `users` del database `dvwa`, recuperando le colonne `user` e `password`.

`sqlmap` ha riconosciuto che i valori nella colonna `password` erano hash MD5 e ha offerto di salvarli in un file temporaneo per un uso successivo, cosa che ho accettato. Ho poi rifiutato il cracking automatico integrato nel tool, preferendo usare strumenti dedicati nella fase successiva. I cinque utenti estratti sono stati: `admin`, `gordonb`, `1337`, `pablo` e `smithy`, ciascuno con il proprio hash MD5.

STEP 3 **Preparazione del file degli hash**

Ho copiato il file CSV generato da `sqlmap` sul Desktop e ho creato manualmente un file `users.txt` nel formato atteso da John the Ripper, ovvero `username:hash` su ogni riga. Ho poi creato anche un file separato `hashes.txt` contenente solo gli hash, da usare con Hashcat che non richiede il prefisso con lo username. Avendo notato che due utenti (`admin` e `smithy`) condividono lo stesso hash `5f4dcc3b5aa765d61d8327deb882cf99`, ho incluso solo quattro hash distinti nel file per Hashcat, in modo da evitare elaborazioni duplicate.

STEP 4 **Cracking con John the Ripper**

Ho avviato John the Ripper specificando il formato MD5 raw e la wordlist `rockyou.txt`. Il tool ha analizzato il file `users.txt` e in tempi molto brevi ha completato il cracking di tutti e cinque gli hash. Al termine ho usato il comando `john --show --format=raw-MD5 users.txt` per visualizzare le credenziali recuperate. Il risultato   stato: `admin:password`, `gordonb:abc123`, `1337:charley`, `pablo:letmein`, `smithy:password`. John ha quindi cracato correttamente il 100% degli hash.

STEP 5 **Cracking con Hashcat**

Ho utilizzato Hashcat in modalit  dizionario con il tipo di hash 0 (MD5 raw) e `rockyou.txt` come wordlist, puntando al file `hashes.txt`. Hashcat ha mostrato un avviso relativo all'uso di pure kernel (non ottimizzati), che comporta maggiore compatibilit  con password lunghe ma riduce le prestazioni. La cache del dizionario   stata costruita caricando oltre 14 milioni di voci dal file `rockyou.txt`. Al termine, il risultato ha mostrato Status: Cracked con 4/4 digest recuperati (i quattro hash distinti), confermando le stesse password trovate da John.

STEP 6 Verifica online con Hydra

Come ultimo passaggio ho usato Hydra per eseguire un attacco di brute force direttamente sul form di login della DVWA. Ho specificato la lista degli username con il file `users.txt`, la wordlist `rockyou.txt` come dizionario delle password, l'indirizzo IP del target e il modulo `http-post-form` con i parametri del form e la stringa di errore da riconoscere (`Login failed`). Hydra ha avviato l'attacco con 16 task paralleli, raggiungendo una velocita' di circa 28 milioni di tentativi al minuto. Al termine ha riportato 5 credenziali valide, ma il risultato per l'utente 1337 e' stato errato: Hydra ha trovato 'christopher' anziche' 'charley', che e' la password corretta verificata in precedenza con John e Hashcat.

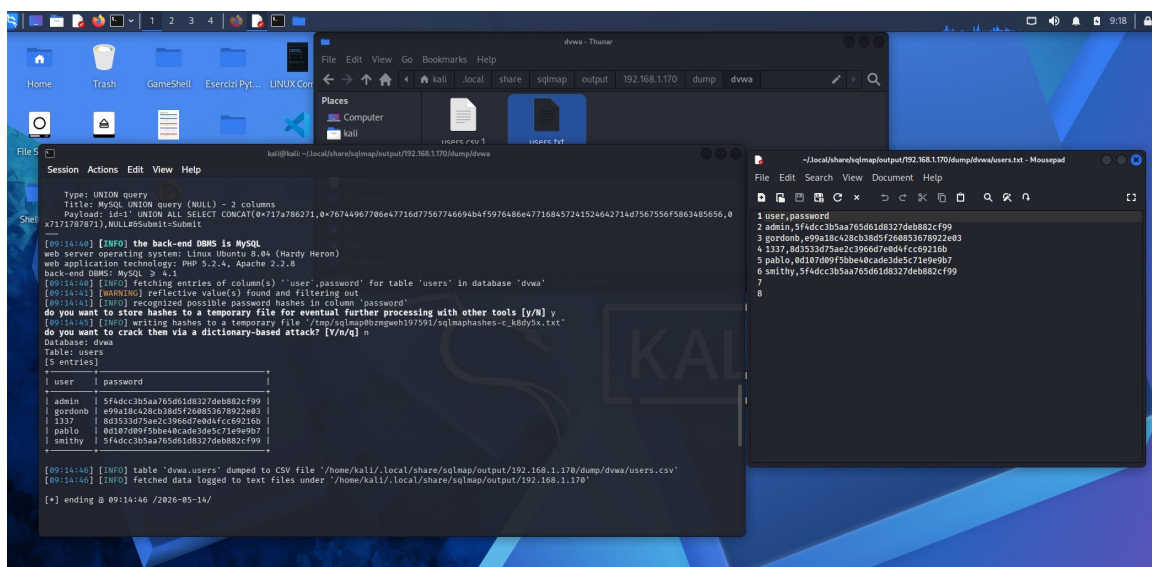
5. Screenshot

Fig. 1 — sqlmap estrae la tabella `users` dal database `dvwa` di Metasploitable 2.0 (192.168.1.170). Sono visibili i cinque record `user/password` con hash MD5, il riconoscimento automatico del DBMS (MySQL >= 4.1) e la scrittura degli hash nel file temporaneo `/tmp/sqlmaphashes-c_k8dy5x.txt`.

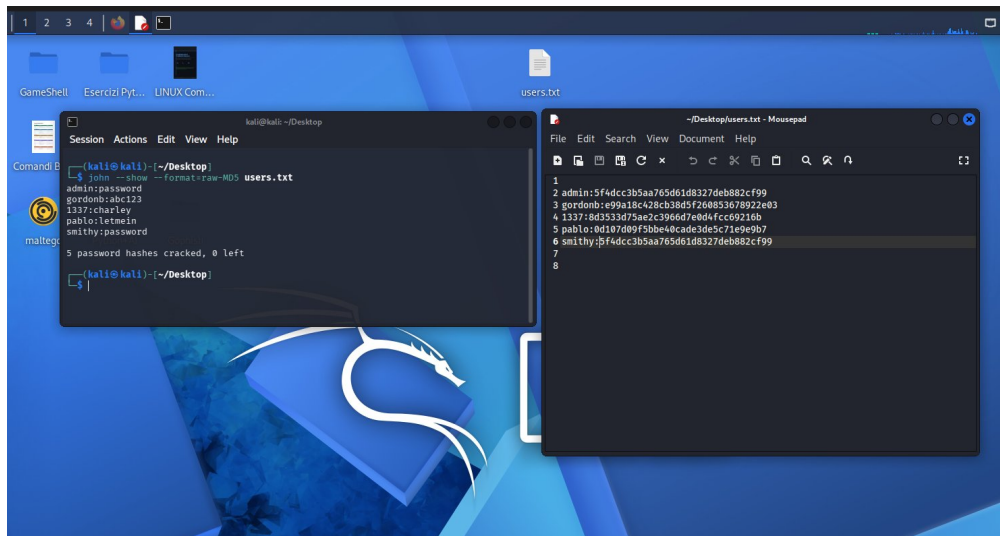


Fig. 2 — John the Ripper mostra le cinque credenziali craccate con il comando `john --show --format=raw-MD5 users.txt`. Tutti e cinque gli hash risultano risolti (5 password hashes cracked, 0 left): admin:password, gordonb:abc123, 1337:charley, pablo:letmein, smithy:password.

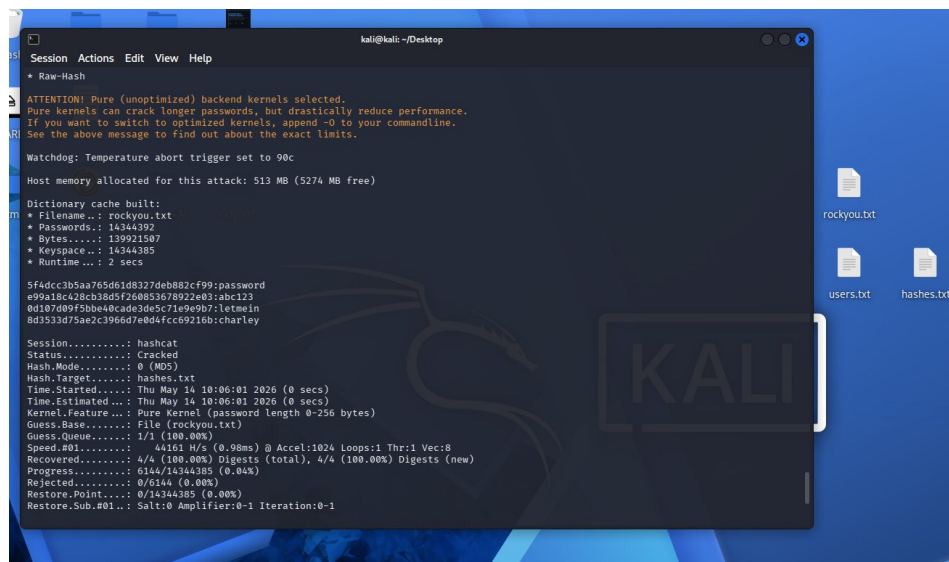


Fig. 3 — Hashcat completa il cracking in modalita' dizionario (MD5, Hash.Mode 0) con rockyou.txt. Il riepilogo finale mostra Status: Cracked, Recovered: 4/4 (100%) Digests. Le quattro coppie hash:password visibili confermano i risultati di John the Ripper.

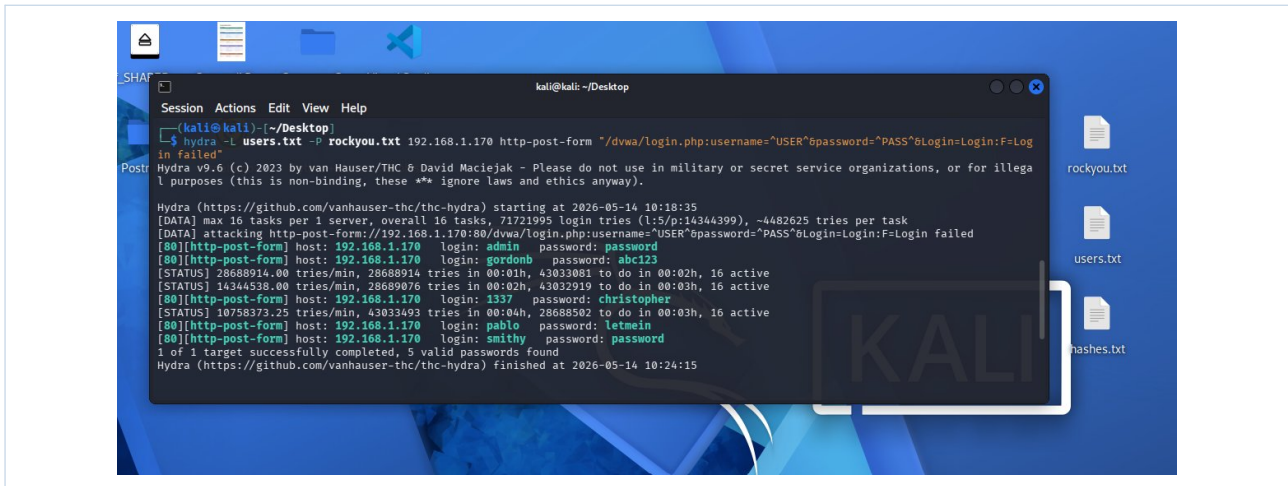


Fig. 4 — Hydra v9.6 completa l'attacco http-post-form su 192.168.1.170. Vengono riportate 5 credenziali valide, ma la password dell'utente 1337 risulta 'christopher' invece di 'charley': questo rappresenta un falso positivo causato dall'ordine delle voci nella wordlist rockyou.txt.

6. Appendice: Comandi Principali

Estrazione del database con sqlmap

```
# Estrazione della tabella users dal database dvwa
sqlmap -u 'http://192.168.1.170/dvwa/vulnerabilities/sqli/?id=1&Submit;=Submit' \
--cookie='PHPSESSID=<SESSION_ID>;security=low' \
-D dvwa -T users -C user,password --dump
```

Cracking con John the Ripper

```
# Cracking offline con dizionario rockyou.txt (formato MD5 raw)
john --wordlist=/usr/share/wordlists/rockyou.txt --format=raw-MD5 users.txt
# Visualizzazione dei risultati salvati nel pot file di John
john --show --format=raw-MD5 users.txt
```

Cracking con Hashcat

```
# Cracking offline con dizionario rockyou.txt (hash mode 0 = MD5)
hashcat -m 0 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
```

Brute force online con Hydra

```
# Attacco al form di login HTTP POST della DVWA
hydra -L users.txt -P rockyou.txt 192.168.1.170 http-post-form \
'/dvwa/login.php:username=^USER^&password;=^PASS^&Login;=Login:F=Login failed'
```

7. Risultati

✓ Estrazione hash completata con sqlmap

sqlmap ha identificato correttamente la vulnerabilit  UNION-based e ha estratto tutti e cinque i record dalla tabella users del database dvwa. Gli hash MD5 sono stati salvati sia in formato CSV che in un file di testo separato, pronti per l'utilizzo con i tool di cracking.

✓ John the Ripper: 5/5 hash craccati correttamente

Tutti e cinque gli hash MD5 sono stati risolti in tempi brevissimi usando la wordlist rockyou.txt. Le credenziali recuperate sono: admin:password, gordonb:abc123, 1337:charley, pablo:letmein, smithy:password. Il 100% degli hash   stato craccato senza alcuna anomalia.

✓ Hashcat: 4/4 hash distinti craccati correttamente

Hashcat ha elaborato i quattro hash unici presenti nel file hashes.txt (admin e smithy condividono lo stesso hash) e li ha risolti tutti con successo. Il riepilogo finale ha confermato Status: Cracked con Recovered: 4/4 (100%) Digests. I risultati sono coerenti con quelli di John the Ripper.

  Hydra: falso positivo per l'utente 1337

Hydra ha riportato 5 credenziali valide, ma la password trovata per l'utente 1337   'christopher' anzich  'charley'. Si tratta di un falso positivo: Hydra ha individuato una combinazione username/password che ha superato il controllo sul form HTML, ma che non corrisponde alla password reale memorizzata nel database. Questo puo' essere dovuto a comportamenti imprevisti del form di login in condizioni di carico elevato, oppure a una risposta HTTP ambigua che Hydra ha interpretato come un login riuscito. In ogni caso, il risultato evidenzia un limite importante del brute force online rispetto al cracking offline.

8. Difficolt  Incontrate

La fase piu' problematica   stata quella con Hydra. Inizialmente non ero sicuro di quale stringa di errore usare per il parametro F= nel modulo http-post-form: ho dovuto analizzare manualmente il sorgente HTML della pagina di login della DVWA per identificare il messaggio esatto restituito in caso di accesso negato. Dopo alcune prove errate ho trovato la stringa corretta 'Login failed' che ha permesso a Hydra di distinguere i tentativi riusciti da quelli falliti.

Un altro aspetto che mi ha sorpreso   stato il comportamento di Hashcat: al primo avvio il tool ha mostrato un avviso relativo ai pure kernel, suggerendo di usare il flag -O per attivare i kernel ottimizzati. Ho scelto di non usarlo per mantenere la compatibilit  con password di lunghezza arbitraria, anche se questo ha ridotto la velocit  di elaborazione. Per gli hash semplici di questa esercitazione la differenza non   stata rilevante.

Nota: Il falso positivo prodotto da Hydra per l'utente 1337   un esempio concreto di perch  il brute force online non sia sempre affidabile come metodo di verifica. A differenza del cracking offline, dove si opera direttamente sugli hash con pieno controllo, l'attacco online dipende dal comportamento del server e puo' produrre risultati incoerenti in presenza di latenza di rete, sessioni concorrenti o logiche applicative particolari.

9. Conclusioni

Questa esercitazione mi ha permesso di mettere in pratica diversi strumenti di password cracking in un contesto realistico, partendo dall'estrazione degli hash tramite SQL injection fino alla verifica delle credenziali sul form di login. Ho potuto osservare direttamente le differenze tra approccio offline e online: mentre John the Ripper e Hashcat lavorano sugli hash in locale con grande affidabilità e velocità, Hydra interagisce direttamente con il servizio remoto ed è soggetto a più variabili che possono influenzare i risultati.

Il fatto che Hydra abbia prodotto un falso positivo per l'utente 1337 è stato un momento formativo importante: mi ha fatto capire che nel pentesting non basta ottenere un risultato, bisogna sempre verificarlo con più fonti e metodi. In questo caso, il confronto con i risultati di John e Hashcat ha reso subito evidente l'inconsistenza.

Nel complesso ritengo di aver raggiunto tutti gli obiettivi prefissati. Ho acquisito familiarità con l'uso di sqlmap per l'estrazione di dati sensibili da database vulnerabili, e ho imparato a configurare correttamente i tre tool di cracking sia dal punto di vista dei parametri tecnici che dell'interpretazione dei risultati. Queste competenze sono fondamentali per comprendere l'importanza di memorizzare le password con algoritmi di hashing sicuri e salted, invece di hash MD5 non salati come quelli usati in DVWA.

Report redatto nell'ambito del Corso di Cybersecurity & Ethical Hacking (A.Y. 2025/2026) a soli fini didattici.